Writeup: Santa Logs — The Hackers Labs

Autor: Kevin José Araujo **Fecha:** Octubre 2026 **Fuente del reto:** The-Hackers-Labs (JuanAntonioRodriguez68) **Categoría:** Análisis forense de logs de Windows (EVTX) + desencriptado AES **Objetivo:** Encontrar la flag oculta en un script malicioso detectado en el sistema de Santa Claus.

> *Nota: la resolución del reto (escaneo, enumeración, diagnóstico de errores y obtención de la flag) fue realizada por el autor. Se contó con apoyo de IA para la redacción y organización de este documento, tras no encontrar una solución clara en fuentes web para algunos de los errores técnicos presentados.*

---

1. Requisitos previos — Instalación de herramientas en Kali Linux

Antes de empezar, se instalan todas las herramientas necesarias para completar el reto. La mayoría ya vienen incluidas en Kali, pero algunas requieren instalación manual:

```
# Actualizar repositorios
sudo apt update

# arp-scan (localización de hosts en la red)
sudo apt install arp-scan -y

# nmap (escaneo de puertos) — normalmente ya viene instalado en Kali
sudo apt install nmap -y

# crackmapexec (validación de credenciales y enumeración SMB)
sudo apt install crackmapexec -y

# smbclient (acceso a recursos compartidos SMB)
sudo apt install smbclient -y

# strings (extracción de texto de binarios) — incluido en binutils, ya viene en Kali
sudo apt install binutils -y

# Librería python-evtx (conversión de logs .evtx a texto)
# Se recomienda clonar el repositorio directamente en vez de usar el paquete de apt,
# ya que evita problemas de compatibilidad entre versiones:
cd ~
git clone https://github.com/williballenthin/python-evtx.git
cd python-evtx
pip install . --break-system-packages

# pycryptodome (desencriptado AES del script malicioso)
pip install pycryptodome --break-system-packages
```

> Si `pip install` da el error `externally-managed-environment`, el parámetro `--break-system-packages` ya incluido arriba lo resuelve. Si aun así falla, se puede usar `pipx` como alternativa (`sudo apt install pipx`).

Con esto instalado, se puede seguir el resto del taller sin interrupciones por dependencias faltantes.

---

2. Contexto del reto

Un equipo de trolls se infiltró en la "Red de Regalos 3000" del Polo Norte. La misión tiene tres partes:

1. Revisar los logs del sistema para descubrir cuándo, dónde y cómo se infiltraron los trolls.
2. Encontrar el virus escondido en el sistema, el cual contiene una flag secreta.
3. Restablecer el sistema antes de la medianoche del 24 de diciembre.

Credenciales iniciales proporcionadas por el enunciado:

```
Login: santa
Password: Cl@us
```

---

3. Localización del objetivo

Se escanea la red local para identificar la máquina víctima:

```
sudo arp-scan --interface eth0 -l
```

Resultado:

```
192.168.0.13   08:00:27:6b:19:17   PCS Systemtechnik GmbH
```

---

4. Verificación de conectividad

```
ping -c1 192.168.0.13
```

Confirma que el host está activo y responde (`1 packets transmitted, 1 received, 0% packet loss`).

---

5. Escaneo de puertos

```
nmap -p- -Pn -sVCS --min-rate 5000 192.168.0.13 -T 2
```

Puertos relevantes encontrados:

Puerto	Servicio	Detalle
135/tcp	msrpc	Microsoft Windows RPC
139/tcp	netbios-ssn	Microsoft Windows netbios-ssn
445/tcp	microsoft-ds	Microsoft Windows Server 2008 R2 - 2012

5985/tcp	http	Microsoft HTTPAPI httpd 2.0 (WinRM)
49668/tcp	msrpc	Microsoft Windows RPC

El puerto **445 (SMB)** es el punto de entrada, dado que ya tenemos credenciales.

---

6. Enumeración SMB

5.1 Validar credenciales

```
crackmapexec smb 192.168.0.13 -u 'santa' -p 'Cl@us'
```

Resultado: `[+] WIN-VRU3GG3DPLJ\santa:Cl@us (Pwn3d!)` — credenciales válidas.

5.2 Listar recursos compartidos

```
crackmapexec smb 192.168.0.13 -u santa -p Cl@us --shares
```

Recursos disponibles:

Share	Permisos
ADMIN$	READ, WRITE
C$	READ, WRITE
IPC$	—

Con permisos de escritura en `C$`, se puede navegar todo el disco del sistema.

5.3 Acceder al recurso C$

```
smbclient -U 'santa' //192.168.0.13/C$
```

---

7. Extracción de los logs de Windows

Los logs de eventos de Windows se almacenan por defecto en:

```
\Windows\System32\winevt\Logs
```

```
smb: \> cd \Windows\System32\winevt\Logs
smb: \Windows\System32\winevt\Logs\> dir
```

Entre los archivos listados aparece uno con nombre distintivo:

```
Santalogs.evtx   A   69632   Wed Dec 11 05:36:45 2024
```

Se descarga a la máquina local:

```
smb: \Windows\System32\winevt\Logs\> get Santalogs.evtx
smb: \Windows\System32\winevt\Logs\> exit
```

---

8. Conversión de .evtx a texto legible

El formato `.evtx` es binario, así que se necesita convertirlo. La herramienta de referencia es `evtx_dump` (librería `python-evtx`).

Problemas encontrados y cómo se resolvieron

Durante la práctica aparecieron varios obstáculos típicos de este tipo de herramientas en Kali, que vale la pena documentar:

1. `evtx_dump.py: command not found` → la herramienta no viene preinstalada. Se resolvió instalando la librería (`apt install python3-evtx` o clonando el repo oficial `williballenthin/python-evtx`).
2. `ModuleNotFoundError: No module named 'scripts'` al usar el binario `/usr/bin/evtx_dump` de apt → bug conocido del empaquetado; se evita ejecutando el script directamente desde el repositorio clonado en vez del lanzador de apt.
3. **Carpeta `scripts` no encontrada** → en versiones recientes del repo, la carpeta se llama `evtx_scripts` en lugar de `scripts`.
4. `ModuleNotFoundError: No module named 'Evtx._vendor'` → el script tomaba la librería `Evtx` instalada por apt (incompleta) en vez de la del propio repositorio clonado. Se corrigió forzando la ruta con `PYTHONPATH`:

```
PYTHONPATH=. python3 evtx_scripts/evtx_dump.py Santalogs.evtx > archivo.txt
```

Alternativa que funcionó finalmente

Dado que el archivo es pequeño y el texto de interés está en UTF-16, también es válido extraer las cadenas directamente sin pasar por `evtx_dump`:

```
strings -e l Santalogs.evtx > archivo.txt
```

---

9. Análisis del archivo de texto

```
grep -i -A5 "<EventData>" archivo.txt | head -n 60
```

Mensajes clave encontrados dentro de los eventos:

```
Admin Note: The temporary access key is 'FTP25_SMB192.168.1.101'
Elf Report: Naughty Virus detected! Santa's logs have been tampered with!
```

```
Elf Alert: Suspicious script 'malicious_script.py' detected in C:\tmp.
It seems to require a special key for decryption! login attempt for user: user23
```

Recapitulando lo encontrado:

- Hay un script sospechoso en `C:\tmp`.
- Hay una clave temporal: `FTP25_SMB192.168.1.101`.
- El script necesita esa clave para desencriptar su contenido.

---

10. Localizar y descargar el script malicioso

```
smbclient -U 'santa' //192.168.0.13/C$
smb: \> cd tmp
smb: \tmp\> dir
smb: \tmp\> get malicious_script.py
smb: \tmp\> exit
```

---

11. Ejecutar el script y desencriptar la flag

El script usa la librería `Crypto` (de **pycryptodome**) para desencriptar con AES. Si no está instalada:

```
pip install pycryptodome --break-system-packages
```

Ejecución:

```
python3 malicious_script.py
```

El script solicita la **clave AES**. Se introduce la clave encontrada en el paso 8:

```
FTP25_SMB192.168.1.101
```

Resultado:

```
[+] Mensaje desencriptado: FLAG: oscar_feliz_navidad
```

---

12. Flag final

```
oscar_feliz_navidad
```

Resumen del flujo completo

1. Instalar herramientas necesarias (`arp-scan` , `nmap` , `crackmapexec` , `smbclient` , `python-evtx` , `pycryptodome`).
2. `arp-scan` → ubicar el host.
3. `ping` → confirmar conectividad.
4. `nmap` → identificar SMB (445) como punto de entrada.
5. `crackmapexec` → validar credenciales y listar shares.
6. `smbclient` → acceder a `C$` y extraer `Santalogs.evtx` .
7. `evtx_dump / strings` → convertir el log a texto legible.
8. `grep` → encontrar la clave temporal y la ruta del script malicioso.
9. `smbclient` → descargar `malicious_script.py` desde `C:\tmp` .
10. Ejecutar el script con **pycryptodome** y la clave AES hallada.
11. Obtener la flag: `oscar_feliz_navidad` .